

CUADERNILLO DE ESTUDIO

CLASE 2

*“Fundamentos de Seguridad (CID)
y Debrief de la Huella Digital”*

Profesor: Mg. Ing. Rodrigo Atilio Elgueta

Unidad: Unidad 1

Datos del/la estudiante

Nombre y apellido: _____

Grupo / N.º: _____

Correo: _____

Fecha: _____

Índice

1. ¿Qué vivimos la semana pasada? (Debrief)	2
2. Los 5 conceptos fundamentales	3
2.1. Activo de información	3
2.2. Amenaza	3
2.3. Vulnerabilidad	3
2.4. Impacto	4
2.5. Riesgo	4
3. Los tres pilares CID	6
3.1. Confidencialidad	6
3.2. Integridad	6
3.3. Disponibilidad	6
4. Conectar la demo con la teoría	8
5. Glosario mínimo de la Clase 2	8
6. Cuestionario 1 de autoevaluación	9
7. Respuestas del ejercicio de la Sección 3	11
8. Para seguir profundizando (optativo)	11
9. Espacio para notas personales	11
10. ¿Qué sigue? (Puente a la Clase 3)	12

1. ¿Qué vivimos la semana pasada? (Debrief)

La Clase 1 ingresaste desde tu celular a una página web que parecía inofensiva. Sin que lo notaras de forma clara, esa página **accedió a la cámara de tu dispositivo** y transmitió la imagen a un panel de administración controlado por el docente.

Reflexión

No hubo un “hackeo” sofisticado. Hubo un diseño que aprovechó que no leíste, no notaste o aceptaste un permiso sin pensar. Eso, en un negocio digital real, es una **brecha de seguridad**.

Respondé con tus palabras en cada recuadro:

(1) ¿Qué dato o permiso cediste sin advertirlo plenamente?

(2) ¿Qué mecanismo usó la página para obtenerlo?

(Pista: permisos del navegador, botones de “aceptar”, redirecciones...)

(3) ¿Qué medida concreta habría prevenido o mitigado esto?

(4) ¿A cuál concepto de hoy lo asociás?

(activo, amenaza, vulnerabilidad, impacto, riesgo)

2. Los 5 conceptos fundamentales

Antes de hablar de “seguridad informática” hay que dominar cinco palabras. Todo el curso —y toda la práctica profesional— se apoya en ellas.

2.1 Activo de información

Definición

Cualquier elemento que tenga valor para la organización y deba protegerse.

No es solo “el servidor”. Son activos:

- Los **datos** de clientes (nombres, tarjetas, historial de compras).
- El **software** propio (código de una app, algoritmos).
- El **hardware** (servidores, notebooks, celulares corporativos).
- El **conocimiento** (manuales de proceso, estrategias comerciales).
- La **reputación** de la marca.
- Las **personas** (sus credenciales, su acceso).

Para un e-commerce: la base de datos con 50 000 clientes, el código de la pasarela de pago, el servidor donde corre la tienda, la cuenta de Instagram con 200 000 seguidores.

2.2 Amenaza

Definición

Un evento o actor potencial que puede causar daño a un activo.

La amenaza **no es el daño en sí**, es la *posibilidad* de que algo malo pase.

- Un atacante que envía correos de **phishing**.
- Un **ransomware** que cifra los discos.
- Un empleado que hace clic donde no debe (**ingeniería social**).
- Un desastre natural que inunda el data center.
- Un competidor que hace **scraping** agresivo de tu catálogo.

2.3 Vulnerabilidad

Definición

Una debilidad en un activo, proceso o control que puede ser explotada por una amenaza.

La vulnerabilidad **está en tu lado**, no en el atacante.

- Un software sin parches de seguridad.
- Una contraseña débil como 123456.
- **No leer los permisos** que pide una página o app (¡lo que pasó en la Clase 1!).
- Un empleado que no recibió capacitación.
- Un bucket de almacenamiento en la nube configurado como “público”.

2.4 Impacto

Definición

La consecuencia (económica, legal, reputacional, operativa) que se materializa cuando una amenaza explota una vulnerabilidad.

Tipo	Ejemplo
Económico	Multa de la AAIP por filtración; pérdida de ventas durante 48h de caída.
Legal	Demanda colectiva; sanción por incumplimiento de Ley 25.326.
Reputacional	Tendencia negativa en redes; pérdida de confianza.
Operativo	No se pueden procesar pagos durante un fin de semana largo.

2.5 Riesgo

Definición

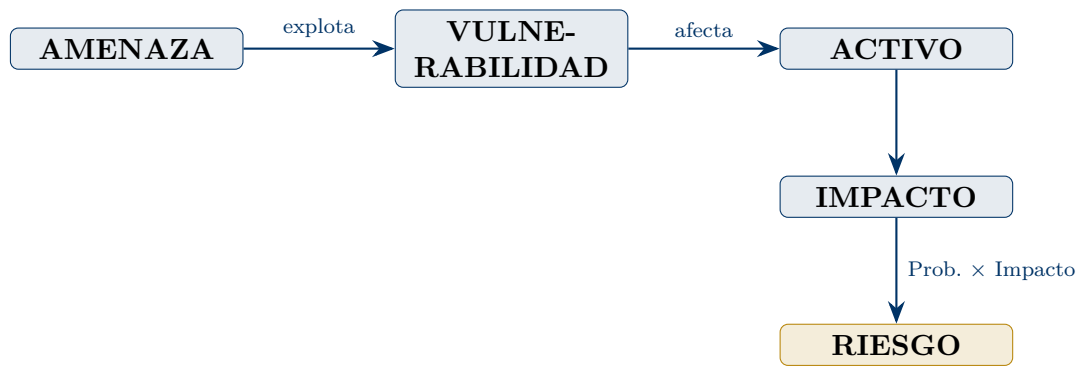
La combinación de la **probabilidad** de que una amenaza explote una vulnerabilidad y el **impacto** que eso generaría.

$$\text{RIESGO} \approx \text{PROBABILIDAD} \times \text{IMPACTO}$$

Para un e-commerce argentino chico:

- **Activo:** base de datos de 5 000 clientes con datos de tarjeta.
- **Amenaza:** ataque de phishing a un empleado de atención al cliente.
- **Vulnerabilidad:** el empleado no fue capacitado y usa la misma contraseña en el mail corporativo y en sitios personales.
- **Impacto:** robo de datos de tarjetas → multa + pérdida de clientes + nota en medios.
- **Riesgo:** ALTO, porque la probabilidad es media-alta y el impacto es severo.

Esquema resumen



3. Los tres pilares CID

La seguridad de la información se sostiene sobre tres propiedades. Si alguna se rompe, hay un **incidente**.

3.1 Confidencialidad

Definición

La información solo es accesible para quienes están **autorizados**.

Se cumple cuando...	Se viola cuando...
Solo RR. HH. ve los sueldos.	Un empleado reenvía la nómina por error a todo el equipo.
La conexión usa HTTPS.	La demo de Clase 1: la cámara se activó sin consentimiento.
Cifrado extremo a extremo.	Un bucket de S3 queda “público” y cualquiera descarga datos.

3.2 Integridad

Definición

La información es **exacta y completa**, y no fue modificada sin autorización.

Se cumple cuando...	Se viola cuando...
Un hash SHA-256 coincide con el original.	Un atacante modifica precios en la base de datos.
Registros contables sin alteraciones.	Un ransomware cifra y corrompe archivos.
Un correo llega sin modificaciones.	Alguien edita una factura PDF antes de reenviarla.

3.3 Disponibilidad

Definición

La información y los sistemas están **accesibles cuando se los necesita**.

Se cumple cuando...	Se viola cuando...
El e-commerce funciona un Black Friday.	Un DDoS deja la tienda offline 12 horas.
Hay backups probados y plan de recuperación.	Se borra la base y no hay backup hace 3 meses.
Pagos procesados 24/7.	Corte de energía sin UPS ni generador.

Regla mnemotécnica

Confidencialidad → ¿Quién lo ve?

Integridad → ¿Está intacto?

Disponibilidad → ¿Puedo usarlo cuando lo necesito?

#	Escenario	Pilar
1	Un ex empleado publica en redes la lista de clientes.	☐
2	Un malware modifica cuentas bancarias destino en una fintech.	☐
3	Un DDoS deja caída la app de delivery toda la hora del almuerzo.	☐
4	Base de datos cifrada pero legible por cualquier empleado.	☐
5	El servidor de backups se corrompe; 6 meses ilegibles.	☐
6	Interceptación de HTTP sin cifrar; se leen datos de tarjeta.	☐

4. Conectar la demo con la teoría

Volvamos a lo que pasó la Clase 1 y clasifiquémoslo:

Activo	Tu imagen personal, tu cámara, tu privacidad.
Amenaza	El sitio web diseñado para acceder a la cámara sin evidencia clara.
Vulnerabilidad	Aceptar permisos sin leer; no verificar la URL; confianza ciega en un enlace.
Impacto	Tu foto terminó en un panel que no controlás. En escala real: chantaje, suplantación, exposición pública.
Riesgo	Alto si la página fuera maliciosa y el activo fueran datos sensibles.
Pilar CID violado	Confidencialidad (se accedió a tu imagen sin autorización consciente).

Si una página “inocente” puede hacer esto, pensá qué puede hacer un competidor, un ciberdelincuente o un empleado interno malintencionado con acceso a los activos de tu empresa. La seguridad no es un gasto: es un **habilitador de confianza** (concepto clave del programa).

5. Glosario mínimo de la Clase 2

Término	Definición en una línea
Activo de información	Todo lo que tiene valor y debe protegerse.
Amenaza	Evento o actor que <i>puede</i> causar daño.
Vulnerabilidad	Debilidad que la amenaza puede explotar.
Impacto	Consecuencia del daño materializado.
Riesgo	Probabilidad × Impacto.
Confidencialidad	Solo accede quien está autorizado.
Integridad	La información no fue alterada indebidamente.
Disponibilidad	La información está accesible cuando se necesita.
Huella digital	Rastro de datos que dejamos al usar tecnología.
Permiso (app/navegador)	Autorización para acceder a un recurso del dispositivo.

6. Cuestionario 1 de autoevaluación

Este cuestionario se realiza al cierre de la clase (Kahoot / Forms / papel). **No es eliminatorio.** Usalo para medir cuánto entendiste antes de seguir. Las respuestas correctas están marcadas con ✓ al final de la sección.

1. ¿Qué significa la sigla CID en seguridad de la información?
 - a) Control, Inspección, Detección
 - b) Confidencialidad, Integridad, Disponibilidad
 - c) Ciberseguridad, Información, Datos
 - d) Confianza, Identidad, Datos
2. Un activo de información es:
 - a) Solo el hardware de una empresa
 - b) Cualquier elemento que tenga valor para la organización y deba protegerse
 - c) Únicamente los datos personales de los clientes
 - d) El software antivirus instalado
3. La diferencia entre amenaza y vulnerabilidad es:
 - a) Son sinónimos
 - b) La amenaza es un evento potencial dañino; la vulnerabilidad es una debilidad que puede ser explotada
 - c) La vulnerabilidad es externa y la amenaza es interna
 - d) No hay diferencia relevante para el negocio
4. En la demo de la Clase 1, ¿qué permiso del dispositivo se solicitó sin que el usuario lo notara conscientemente?
 - a) Ubicación GPS
 - b) Cámara
 - c) Contactos
 - d) Micrófono
5. La “huella digital” se refiere a:
 - a) Solo las huellas dactilares usadas en biometría
 - b) El rastro de datos e información que dejamos al usar tecnología
 - c) Un tipo de malware
 - d) La firma digital de un documento
6. ¿Cuál describe mejor un **riesgo** (y no solo una amenaza) para un e-commerce?

- a) Que exista phishing en internet en general
 - b) La probabilidad de que un ataque de phishing exitoso cause pérdida de datos de tarjetas y sanciones regulatorias
 - c) Tener una vulnerabilidad de software sin explotar
 - d) Ninguna de las anteriores
7. La seguridad de la información en un negocio digital debe entenderse principalmente como:
- a) Un gasto que hay que minimizar
 - b) Un habilitador de confianza y una ventaja competitiva
 - c) Un tema exclusivo del área de sistemas
 - d) Una obligación solo para empresas grandes
8. Verdadero o Falso: la disponibilidad se refiere a que la información esté accesible solo para quien está autorizado.
- ☐ Verdadero ☐ Falso

✓ Clave de respuestas

1. **b)** Confidencialidad, Integridad, Disponibilidad
2. **b)** Cualquier elemento que tenga valor...
3. **b)** La amenaza es un evento potencial dañino...
4. **b)** Cámara
5. **b)** El rastro de datos e información...
6. **b)** La probabilidad de que un ataque de phishing...
7. **b)** Un habilitador de confianza...
8. **Falso.** Eso describe a la confidencialidad; la disponibilidad es que la información esté accesible *cuando se la necesita*.

7. Respuestas del ejercicio de la Sección 3

#	Escenario	Pilar afectado
1	Ex empleado publica lista de clientes	C
2	Malware modifica cuentas bancarias destino	I
3	DDoS deja caída la app de delivery	D
4	Base cifrada pero legible por cualquier empleado	C
5	Backups de 6 meses corruptos	D e I
6	Interceptación de HTTP sin cifrar	C

8. Para seguir profundizando (optativo)

Recurso	Qué vas a encontrar
ISO/IEC 27000 (glosario)	Definiciones formales de activo, amenaza, vulnerabilidad, riesgo.
haveibeenpwned.com	Verificá si tu mail apareció en alguna brecha de datos pública.
INCIBE — Guía de ciberseguridad para pymes	Lenguaje simple, ejemplos prácticos.
Video: “HTTP vs HTTPS”	Para entender por qué el cifrado protege la confidencialidad.

9. Espacio para notas personales

Usá este espacio durante la clase para anotar dudas, ejemplos útiles o preguntas para la próxima clase.

10. ¿Qué sigue? (Puente a la Clase 3)

La próxima clase vamos a:

- Ver el **panorama de amenazas** más comunes para negocios digitales (phishing, ransomware, ingeniería social).
- Probar **herramientas gratuitas reales**: Have I Been Pwned, VirusTotal, un gestor de contraseñas.
- **Conformar los grupos de 4-5** que van a trabajar todo el cuatrimestre, incluida la consigna del **Trabajo Práctico Integrador**.

👉 **¡Traé el celular con batería!**

Vamos a usar herramientas en vivo.